

Security Education, Training and Awareness

A practical program blueprint for MeCo

MODULE 10 DISCUSSION

Prepared for Robin Georgiou, Chief Security Officer
Prepared by Sam Dirr

Use NIST as the primary framework

Pair the framework with SANS templates to speed up a focused, measurable SETA launch.

MeCo should base its program on NIST SP 800-50 Rev. 1. It offers a current, vendor-neutral lifecycle for awareness, training, education, behavior change, and evaluation. The SANS toolkit supplies practical materials that make execution easier.

What a focused SETA program covers

Program element	Purpose
Awareness	Keep everyday threats, reporting, and secure habits visible.
Training	Build role-based knowledge and skills for higher-risk work.
Education	Develop deeper capability for security and technical roles.
Measurement	Show whether learning and behaviors improve over time.

Selection criteria

Current authoritative guidance • Practical launch tools • Role-based learning • Continuous improvement

NIST SP 800-50 Rev. 1

Building a Cybersecurity and Privacy Learning Program, September 2024

What it is

A government-developed lifecycle guide for organizations creating or managing a cybersecurity and privacy learning program. NIST states that the approach can serve large or small organizations, including those starting a new program.

Recommended steps

1	Define scope, sponsorship, audiences, risks, and objectives.
2	Design role-based learning, communications, and accessible materials.
3	Deliver and manage the program across the organization.
4	Evaluate outcomes, use metrics, and update the program as needs change.

Why it matters

The guidance connects learning to behavior change, organizational risk, and an ongoing evaluation cycle. That gives MeCo a durable program structure rather than a one-time compliance course.

Source: NIST SP 800-50 Rev. 1 (2024), <https://csrc.nist.gov/pubs/sp/800/50/r1/final>

SOURCE 2

SANS Planning Toolkit

Security Awareness Planning Toolkit: practical materials for launching or improving a program

What it is

A practitioner-developed toolkit with a sample project charter and plan, leadership presentation, metrics matrix, phishing planning guide, maturity model, annual program schedule, and benchmark report.

Suggested use at MeCo

1	Adapt the project charter and plan for ownership, scope, and milestones.
2	Use the leadership materials to explain the program and secure support.
3	Set measures with the metrics matrix and plan a relevant phishing activity.
4	Build an annual calendar, then use the maturity model to guide improvements.

Where it helps most

SANS makes the first implementation cycle faster because it provides examples and templates. MeCo should tailor each item to its own policies, risk profile, workforce, and reporting processes.

Source: SANS Institute, Security Awareness Planning Toolkit (updated June 4, 2022), <https://www.sans.org/tools/security-awareness-planning-toolkit>

Framework first, toolkit second

Use the sources together, with clear roles for each.

Criterion	NIST SP 800-50 Rev. 1	SANS Planning Toolkit
Primary value	Full program lifecycle and governance.	Ready-to-use planning materials.
Strength	Current, authoritative, vendor-neutral guidance.	Practical templates, metrics ideas, and program examples.
Best use	Set the program's objectives, roles, measures, and improvement cycle.	Accelerate the launch and supplement program operations.

Recommendation

MeCo should adopt NIST SP 800-50 Rev. 1 as its governing source. It is the more current and complete foundation for a new program, and it directly addresses behavior change, role-based learning, and evaluation. The SANS toolkit should support implementation, not replace the framework.

Decision

Use NIST to define the program. Use SANS artifacts to plan, communicate, measure, and improve the first year.

A 90-day starting point

Begin with a small cycle that establishes ownership, priorities, and a baseline for improvement.

Days 1-30

Name an executive sponsor and program owner. Identify priority human risks, audiences, current content, reporting channels, and program goals.

Days 31-60

Develop the first role-based plan, communications calendar, reporting guidance, baseline course, and measurement approach.

Days 61-90

Launch the baseline course and campaign. Review completion, reporting, and simulation results. Refine the next cycle.

Measures to review

Participation	Completion and role-based coverage.
Behavior	Reporting volume, phishing results, and observed habits.
Program quality	Learner feedback, content relevance, and improvement actions.

First decision
Approve a 90-day SETA launch with an executive sponsor, a named program owner, and baseline measures.

References

National Institute of Standards and Technology. (2024). Building a cybersecurity and privacy learning program (NIST Special Publication 800-50 Revision 1). <https://doi.org/10.6028/NIST.SP.800-50r1>

SANS Institute. (2022). Security Awareness Planning Toolkit. <https://www.sans.org/tools/security-awareness-planning-toolkit>

AI assistance disclosure. OpenAI Codex was used to help locate sources, organize and revise the report, and create the visual layout and graphics. The author reviewed and approved the final content.